Information Security & Vendor Risk Policy

Version 4.2 · Approved by the Board Risk Committee · Effective 1 April 2025

§4 Data localisation

4.1 Any vendor that stores or processes payment or card data on Legion's behalf must store **and process** that data **only in India**, including by sub-processors. No exceptions without Board Risk Committee approval.

§5 Security incidents

5.1 Legion reports cyber incidents to CERT-In within **6 hours** of noticing them.
5.2 Vendors must contractually commit to notify Legion within **2 hours** of detecting an incident affecting Legion data.

§6 Vendor assessments

Critical vendors are reassessed every 12 months. Go-live requires: a current SOC 2 Type II report (period ended within the last 12 months), a valid PCI DSS attestation for card data, and no open critical or high penetration-test findings.

§7 Contract requirements

Contracts with critical vendors must include: India-only data processing, audit and inspection rights for Legion and the RBI (RBI outsourcing directions), a signed data processing agreement aligned to the DPDP Act 2023, and incident-notification timelines.

§8 Tokenisation

Card-on-file data must be tokenised per RBI directions.

Appendix A — Vendor register (extract)

Vendor	Last assessment	PCI DSS valid to	Notes
Arvanta Payments	November 2025 (next due November 2026)	February 2027	Nov 2025 minor security incident reported to CERT-In within **5 hours**. Merchant-admin MFA is **optional** (finding raised).
Brevis Pay	In progress	June 2027	See Brevis security pack.